Laws & Regulations

Topic 2 · Day 2 — Wednesday, October 28, 2026 · 18:30–22:00 · Online

- 420-D04-AB Conformity Assessment · **AEC** (Attestation of College Studies) Cybersecurity LEA.D8 · Cohort CYB-01
- Identifying the legal, regulatory and contractual requirements that apply to an organization

Before we start — the rules of this course

- Educational content only — general education, **not legal advice**
- Fictional company, fictional data: use only the case file and your own lab **VMs** (virtual machines)
- Run the code only in your authorized lab environment
- Check every link before you open it: VirusTotal and Google Safe Browsing
- Do not record, stream or redistribute the sessions or the materials
- Cyber.SoHo Legal Notice, Terms of Use and Acceptable Use Policy (v2.0) — link in every handout

Links: Legal Notice, Terms of Use and AUP ↗ · VirusTotal URL scanner ↗

Recall of Day 1

- **Conformity assessment**: structured, evidence-based verification against requirements
- Three types of audit: first-party · second-party · third-party (+ regulatory)
- **PDCA** (Plan – Do – Check – Act): the assessment is the **Check** step
- The 6-step method: **step 1 = identify the requirements → Lab 1, tonight**
- Tool map: Lynis · CIS-CAT Lite · Policy Analyzer · Nmap · PowerShell / Bash
- Quick question: which tool compares Windows settings with Microsoft's baseline?

Why laws matter for threat and risk

- Risk = **likelihood × impact** (420-D02-AB)
- Laws change the **impact**: duties after an incident (report, notify, record) and sanctions
- Failing a law, a contract or a standard is itself a risk: **legal / compliance risk**
- Tonight: the five texts that apply to Érable Cycles
- After the break: Lab 1, Part A — the Applicability Register

Tonight's objectives

- Place a requirement in the **hierarchy of obligations** and name its enforcer
- Explain when **PIPEDA** (Personal Information Protection and Electronic Documents Act) applies and apply the **RROSH** (real risk of significant harm) test
- List the main obligations of Law 25 and the evidence an auditor asks for
- Explain why the **GDPR** (General Data Protection Regulation) applies to a Montréal retailer; compute the 72-hour deadline
- Define the **CDE** (cardholder data environment); explain how a hosted payment page and **P2PE** (point-to-point encryption) reduce scope
- Check a newsletter against the three **CASL** (Canada's Anti-Spam Legislation) requirements

Meet the case again: Érable Cycles inc.

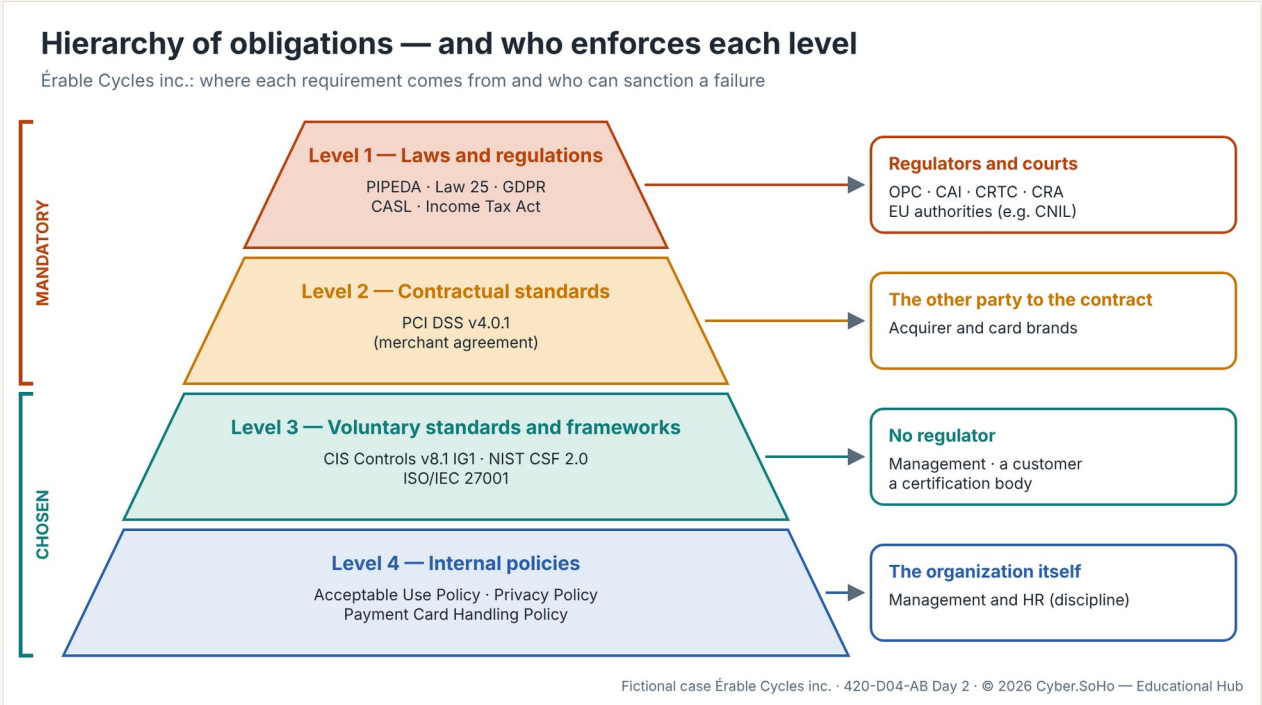
- Montréal head office · stores in Laval and Québec City · 45 employees
- Sells in stores and online to Canada, the United States and the **EU** (European Union) (France, Belgium)
- Customer accounts: name, address, phone, e-mail, order history — no card numbers
- Hosted payment page online · **P2PE** (point-to-point encryption) terminals in the stores
- Monthly newsletter: about 18,000 subscribers
- Six policies, including the Privacy Policy and the Email Marketing Procedure

Tonight's plan

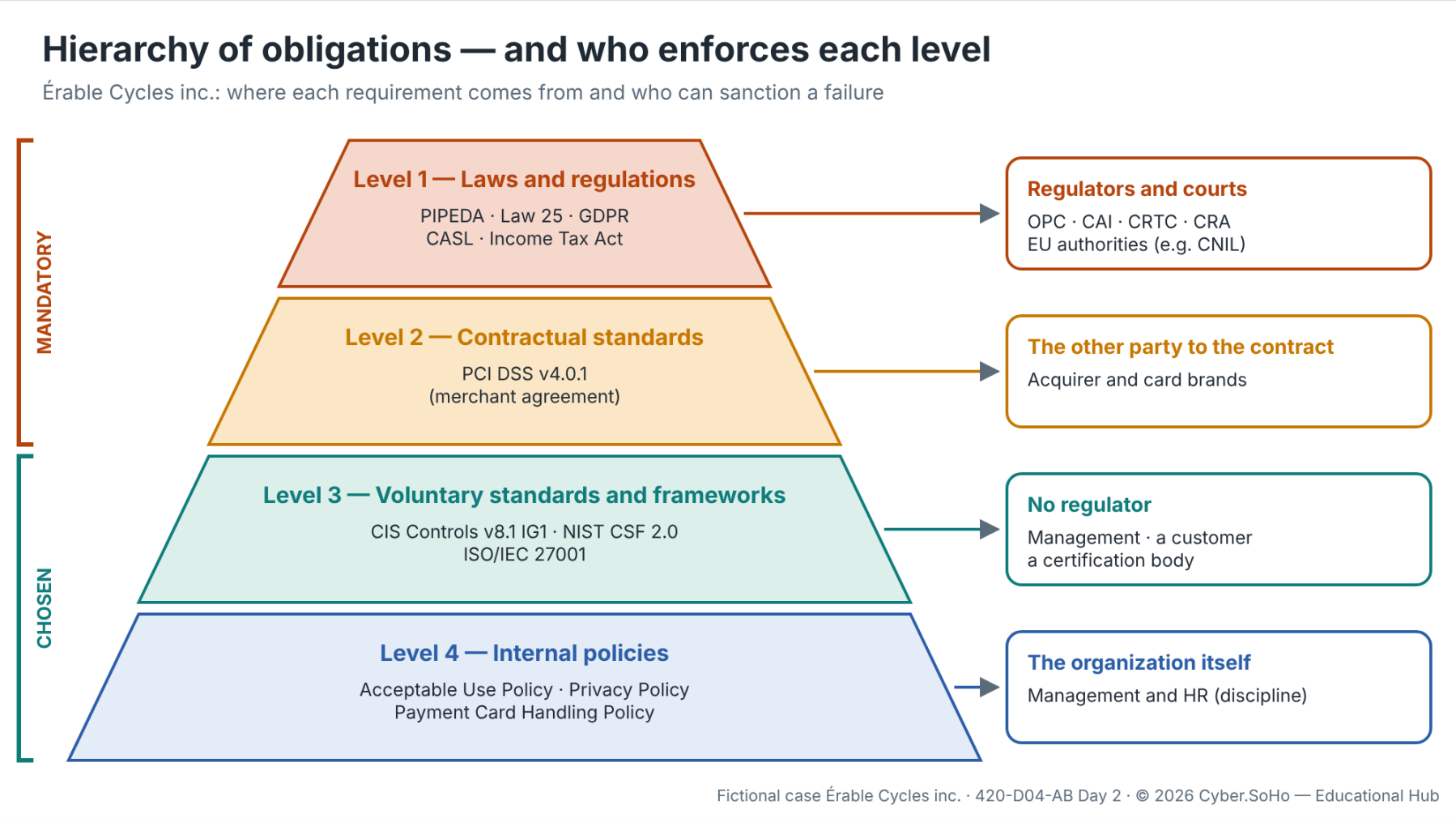
- 18:30 Recall of Day 1 and objectives
- Lesson 1 Landscape · Lesson 2 **PIPEDA** (Personal Information Protection and Electronic Documents Act) · Lesson 3 Law 25
- Lesson 4 **GDPR** (General Data Protection Regulation) · Lesson 5 **PCI DSS** (Payment Card Industry Data Security Standard) · Lesson 6 **CASL** (Canada's Anti-Spam Legislation)
- Mention only: United States state laws · **CRA** (Canada Revenue Agency) record keeping
- 19:30 Break (15 min)
- 19:45–22:00 Lab 1, Part A — guided for 30–45 min, then individual work

Lesson 1 · Requirements: source and binding force

- **Requirement**: something an organization must do or achieve
- **Source**: the document it comes from — law, contract, standard, policy
- **Binding force**: how strongly it obliges, and what happens if it is not met
- Sorted by binding force → the **hierarchy of obligations** (4 levels)



The hierarchy of obligations



Laws, regulations, standards, frameworks, policies

- **Law** (act, statute): adopted by a legislature
- **Regulation**: detailed rule adopted by the government under a law — equally mandatory
- **Standard**: voluntary by itself; mandatory when a **contract** requires it
- **PCI DSS** (Payment Card Industry Data Security Standard) reaches Érable Cycles through its **merchant agreement** with the **acquirer**
- **Framework**: chosen set of practices (**NIST CSF** (National Institute of Standards and Technology Cybersecurity Framework) 2.0, **CIS** (Center for Internet Security) Controls v8.1, **ISO/IEC** (ISO and IEC, the international standards bodies) 27001)
- **Policy**: the organization's own rules for its staff

Who enforces what in Canada

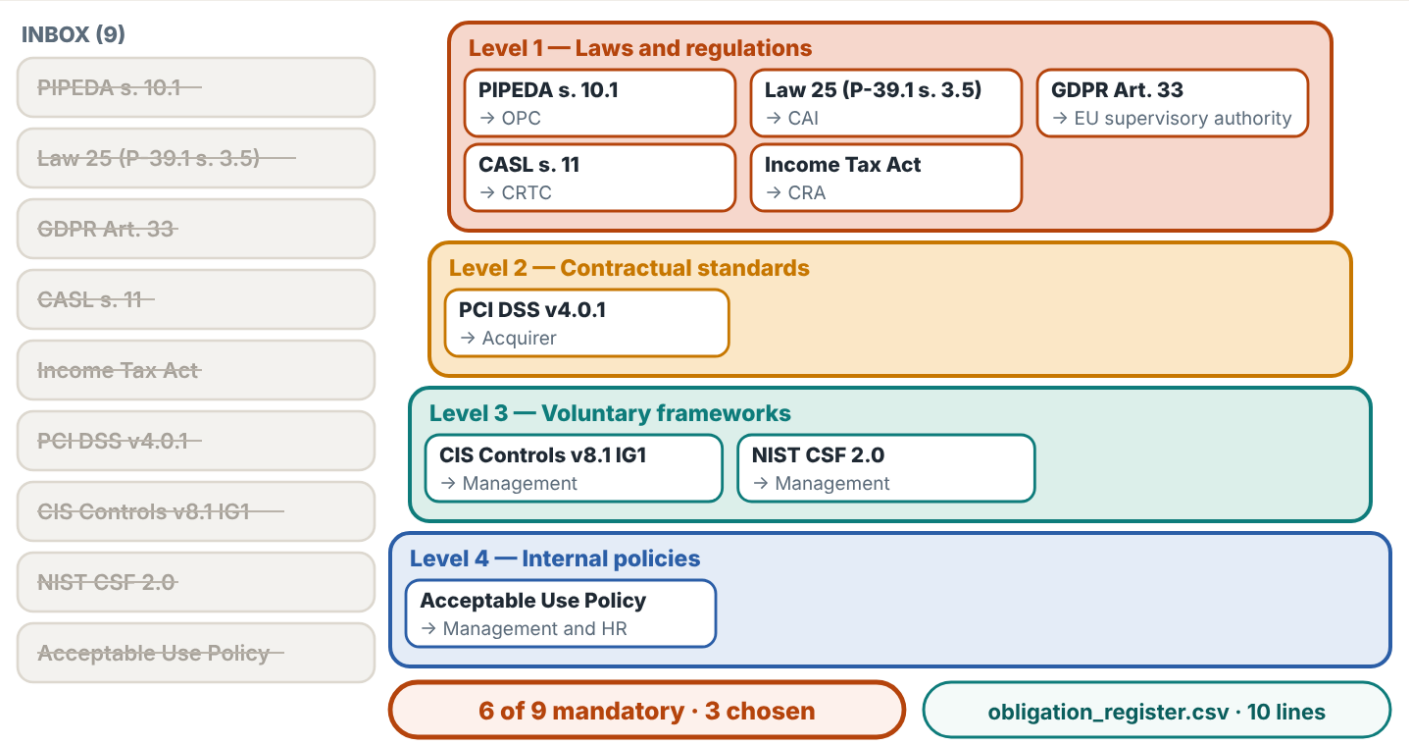
- **OPC** (Office of the Privacy Commissioner of Canada) → **PIPEDA** (Personal Information Protection and Electronic Documents Act) (federal): investigates, receives breach reports; offences prosecuted, fine ≤ $100,000
- **CAI** (Commission d'accès à l'information du Québec) → Law 25 (Québec): inspects, orders, **AMPs** (administrative monetary penalties)
- **CRTC** (Canadian Radio-television and Telecommunications Commission) → **CASL** (Canada's Anti-Spam Legislation): investigations and **AMPs**
- Acquirer and card brands → **PCI DSS** (Payment Card Industry Data Security Standard) (contract)
- **CRA** (Canada Revenue Agency) → tax record keeping
- **EU** (European Union) supervisory authorities (e.g., **CNIL** (France's data protection authority)) → **GDPR** (General Data Protection Regulation)

Applicability and jurisdiction

- **Applicability**: does the text cover us? — who · which information or activity · where
- **Jurisdiction**: territory and subject matter of a law and its regulator
- **Extraterritorial effect**: the **GDPR** (General Data Protection Regulation) covers a Montréal company selling to the **EU** (European Union)
- Lab 1 answer format: **Yes / Partly / No** + one sentence tied to a company fact
- Mandatory first · trace requirement → policy → control → evidence

Example: sorting the to-do list by binding force

- Nine requirements reached the **IT** (information technology) administrator in one week
- The script sorts them by tier rank and names the enforcer
- Result: **6 of 9 are mandatory** (laws + contract); 3 are chosen
- Output: `obligation_register.csv` → Lab 1 register and matrix



Lesson 2 · What PIPEDA covers

- **PIPEDA** (Personal Information Protection and Electronic Documents Act) Part 1: **personal information** in **commercial activities**
- Personal information = information about an identifiable individual
- Québec, British Columbia, Alberta: **substantially similar** laws apply in the province
- **PIPEDA** still applies to information crossing provincial or national borders
- Érable Cycles: Law 25 for Québec activities **+ PIPEDA** for data leaving Québec

The ten fair-information principles

PIPEDA — the ten fair-information principles (Schedule 1)

Principles 4.5 and 4.7 come up in almost every assessment

4.1 Accountability
a person is accountable

4.2 Identifying purposes
say why, before collecting

4.3 Consent
knowledge and consent

4.4 Limiting collection
only what is needed

4.5 Limiting use, disclosure, retention
keep only as long as necessary

4.6 Accuracy
accurate, complete, up to date

4.7 Safeguards
physical · organizational · technological

4.8 Openness
policies available

4.9 Individual access
access on request

4.10 Challenging compliance
complaints handled

Breach of security safeguards (ss. 10.1–10.3, in force since Nov 1, 2018)

Assess RROSH
sensitivity × probability of misuse

→ **Report to the OPC**
as soon as feasible (s. 10.1(1))

→ **Notify individuals**
as soon as feasible (s. 10.1(3))

→ **Notify organizations**
that can reduce harm (s. 10.2)

→ **Record EVERY breach**
keep 24 months (s. 10.3, SOR/2018-64)

Steps 2–4 only when there is a real risk of significant harm (RROSH); step 5 always.

Fictional case Érable Cycles inc. · 420-D04-AB Day 2 · © 2026 Cyber.SoHo — Educational Hub

Meaningful consent

- Valid only if the person can understand **nature, purpose and consequences** (s. 6.1)
- Key elements first: what, with whom, why, risk of harm
- **Express** consent: active agreement (an empty box the person ticks)
- **Implied** consent: reasonably deduced from the situation
- Express consent for sensitive information or unexpected uses
- Érable Cycles: phone for delivery ≠ phone for marketing calls

KEY TERM
Meaningful consent — Consent given by a person who can understand the nature, purpose and consequences (s. 6.1).

KEY TERM
Express / implied consent — Active agreement / consent reasonably deduced from the situation.

Safeguards (4.7) and retention (4.5)

- Safeguards appropriate to **sensitivity**:
  - physical · organizational · technological
- Labs 4–5 produce the evidence: encryption, firewall, access rights
- Principle 4.5: use only for the purposes; keep **only as long as necessary**
- Then destroy, erase or anonymize — documented in a **retention schedule** (Day 3)

KEY TERM

Safeguards (4.7) — Physical, organizational and technological protection matched to sensitivity.

Breaches: the RROSH test (1/2)

- **Breach of security safeguards**: loss of, unauthorized access to or disclosure of **PI** (personal information) caused by a safeguard failure
- Test: **real risk of significant harm** (**RROSH**)
- Significant harm: humiliation, identity theft, financial loss, damage to reputation…
- Two factors: **sensitivity** of the information · **probability** of misuse

Breaches: duties and records (2/2)

1. Contain, assess the two factors, document
2. **RROSH** (real risk of significant harm) → report to the **OPC** (Office of the Privacy Commissioner of Canada) as soon as feasible (s. 10.1(1))
3. Notify the individuals (s. 10.1(3))
4. Notify organizations that can reduce harm, e.g. police (s. 10.2)
5. Record **every** breach — keep **24 months** (s. 10.3, SOR/2018-64)

- Knowingly failing: fine up to $100,000 (s. 28)

Links: OPC breach report form ↗

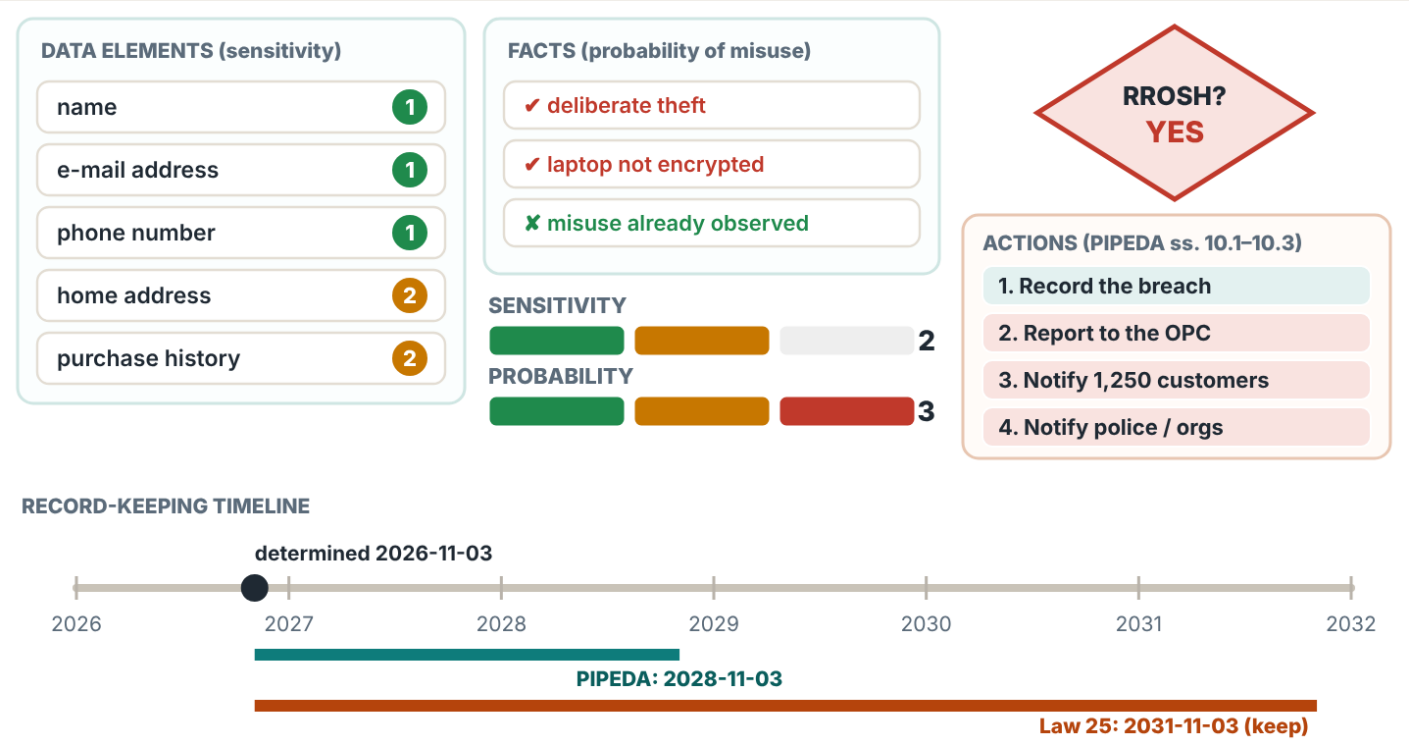
Up-to-date: Bill C-36 (proposed, not in force)

- Tabled June 15, 2026: *Protecting Privacy and Consumer Data Act*
- Would repeal **PIPEDA** (Personal Information Protection and Electronic Documents Act) Part 1; new Digital Safety and Data Protection Commission
- Proposed **AMPs** (administrative monetary penalties): up to $10 M or 3 % of gross global revenue
- Proposed fines: up to $25 M or 5 %
- October 2026: second reading in the House of Commons
- **PIPEDA remains the law in force** — auditors assess against the law in force

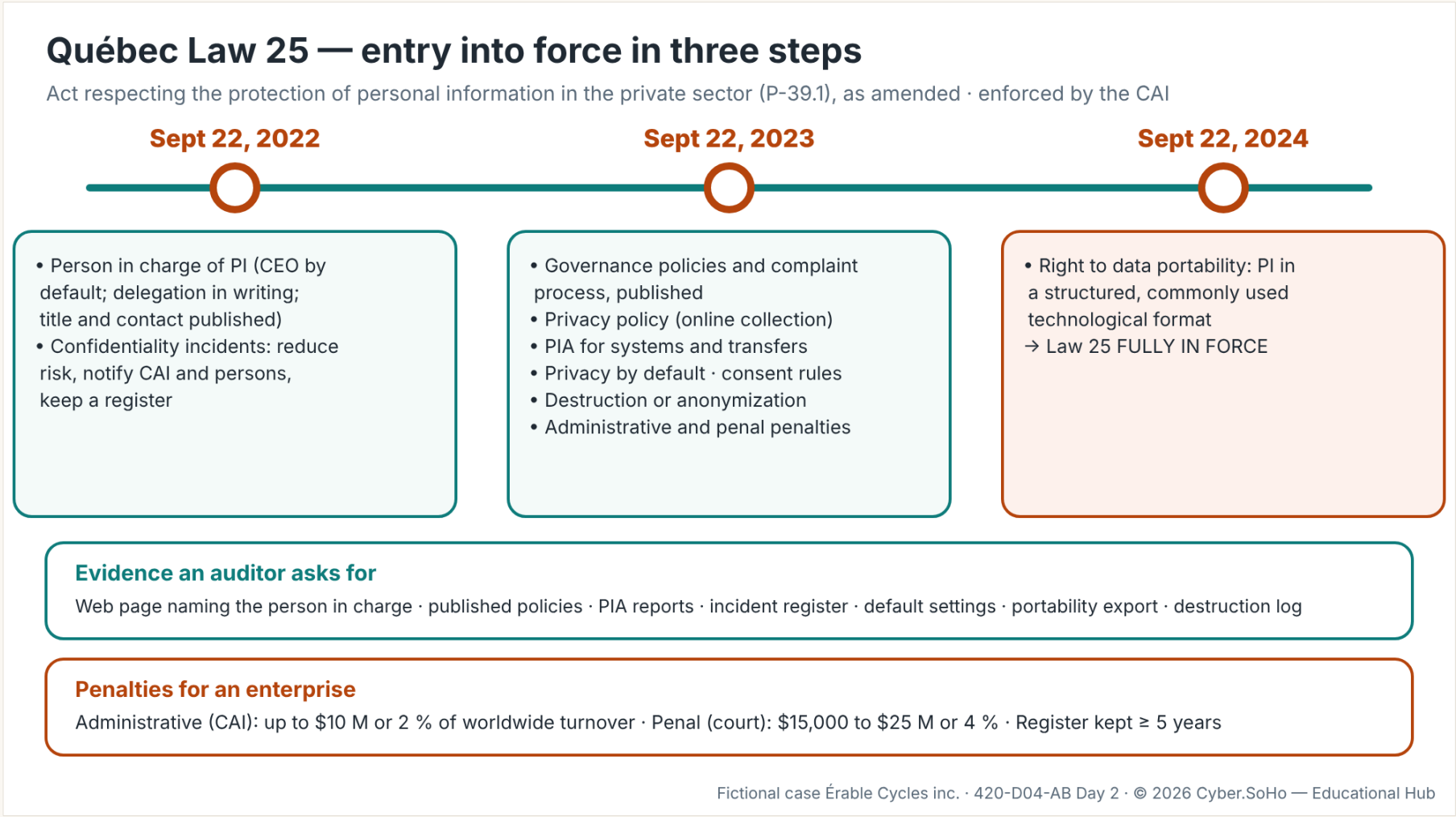
Links: Bill C-36 on LEGISinfo ↗

Example: the stolen laptop in Laval

- Laptop stolen Nov 3, 2026 · 1,250 customers · BitLocker off
- Sensitivity 2 (address + purchase history) · probability 3 (theft + no encryption)
- → **RROSH** (real risk of significant harm) = YES: record, report, notify customers, notify police
- Keep until 2028-11-03 (**PIPEDA** (Personal Information Protection and Electronic Documents Act)) and 2031-11-03 (Law 25) → the longer wins



Lesson 3 · Law 25 in three steps



Governance: the person in charge and published documents

- **Person in charge of PI** (personal information): the **CEO** (chief executive officer) by default; delegation in writing
- Title and contact information **published on the website** (s. 3.1)
- **Governance policies** + complaint process, in clear terms (s. 3.2)
- **Privacy policy** when **PI** is collected online (s. 8.2)
- Auditor's view: easy evidence — a web page, a policy, a procedure, a delegation

KEY TERM
Person in charge of PI (personal information) — By default the person with the highest authority (**CEO** (chief executive officer)); delegation in writing; title and contact published online.

KEY TERM
Governance policies — Published rules on roles, retention, destruction and complaint processing (s. 3.2).

The privacy impact assessment (PIA)

- **PIA** = privacy risks of a project + measures that reduce them, **before** it starts
- Trigger 1: acquire, develop or overhaul an information system involving **PI** (personal information) (s. 3.3)
- Trigger 2: communicate **PI** **outside Québec** (s. 17) — other provinces included
- s. 17: adequate protection + **written agreement**
- Érable Cycles: newsletter moving to a platform hosted in the United States → **PIA**

Confidentiality incidents

- Incident: unauthorized access, use or communication · loss · other breach of protection

1. Reduce the risk of injury; prevent new incidents
2. Assess the **risk of serious injury**: sensitivity · consequences · likelihood
3. Serious → notify the **CAI** (Commission d'accès à l'information du Québec) **and** the persons concerned (s. 3.5)
4. Register **every** incident; keep entries **≥ 5 years** (s. 3.8)

- Compare with **PIPEDA** (Personal Information Protection and Electronic Documents Act): **OPC** (Office of the Privacy Commissioner of Canada), **RROSH** (real risk of significant harm), 24 months

Privacy by default, portability, destruction, consent

- **Privacy by default** (s. 9.1): highest confidentiality settings without any action
- A pre-ticked marketing box contradicts it
- **Data portability** (s. 27): structured, commonly used format, on request
- **Destroy or anonymize** when the purpose is achieved (s. 23)
- **Consent**: manifest, free, enlightened, per purpose; express for sensitive **PI** (personal information)

KEY TERM
Privacy by default — Highest confidentiality settings without action by the person (s. 9.1).

KEY TERM
Data portability — **PI** (personal information) given in a structured, commonly used technological format on request (s. 27).

Law 25 penalties

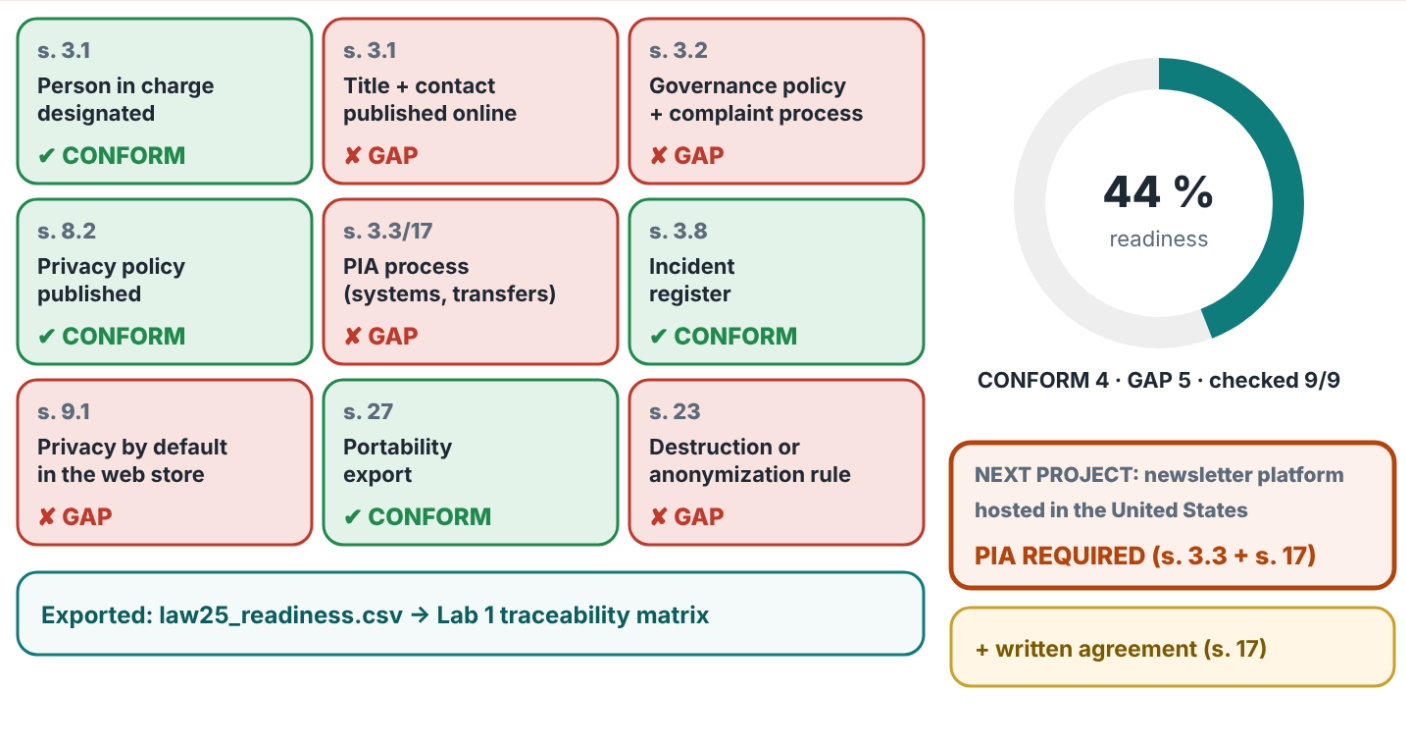
- **AMP** (administrative monetary penalty) by the **CAI** (Commission d'accès à l'information du Québec): up to **$10 M or 2 %** of worldwide turnover
- Penal fine by a court: **$15,000 to $25 M or 4 %** (doubled for a repeat offence)
- Punitive damages in a civil action: at least $1,000 (intentional or gross fault)

KEY TERM

Law 25 / Private Sector Act — S.Q. 2021, c. 25, which modernized Québec's Act respecting the protection of personal information in the private sector (P-39.1).

Example: are we ready for Law 25?

- Nine obligations checked against evidence
- 4 CONFORM · 5 GAP → **readiness 44 %**
- Newsletter on a platform hosted in the United States → **PIA** (privacy impact assessment) **REQUIRED** + written agreement
- Output: `law25_readiness.csv` → Lab 1 traceability matrix



Lesson 4 · Why the GDPR applies to Érable Cycles

- **GDPR** (General Data Protection Regulation) = European Union Regulation (**EU**) 2016/679, applies since May 25, 2018
- Vocabulary: personal data · data subject · processing · **controller** · **processor**
- **Art. 3(2)**: non-EU organizations offering goods or services to people in the **EU**
- Signs (Recital 23): language, currency, delivery — not mere accessibility
- Érable Cycles: delivery to France and Belgium, euros, French checkout → **Partly**

Art. 5 principles and lawful bases

- Lawfulness, fairness and transparency · purpose limitation
- Data minimisation · accuracy · storage limitation
- Integrity and confidentiality · **accountability** (be able to prove it)
- Six lawful bases (Art. 6): consent · contract · legal obligation · vital interests · public task · legitimate interests
- Order = *contract* · newsletter to people in the **EU** (European Union) = *consent*

KEY TERM
Art. 5 principles — Lawfulness-fairness-transparency, purpose limitation, data minimisation, accuracy, storage limitation, integrity-confidentiality; accountability.

KEY TERM
Lawful basis (Art. 6) — Consent, contract, legal obligation, vital interests, public task or legitimate interests.

The articles a non-EU retailer applies

GDPR — the articles a non-EU online retailer must apply

Érable Cycles has no office in the EU but sells to customers in France and Belgium

Does it apply?
Art. 3(2)(a)
Goods offered to people in the EU: delivery, euros, French checkout

How to process
Art. 5 · Art. 6
Principles + accountability; one lawful basis per processing

Who represents you
Art. 27
EU representative designated in writing

Prove it
Art. 30
Records of processing activities (ROPA)

Protect it
Art. 32
Technical and organisational measures (encryption, testing)

When it breaks
Art. 33 · Art. 34
Authority ≤ 72 h after awareness; people if high risk; log every breach

High-risk processing
Art. 35
DPIA before starting

Sanctions
Art. 83
€10 M / 2 % or €20 M / 4 % of worldwide turnover

No EU establishment → no one-stop shop: notify the authority of each member state where affected customers live (EDPB guidelines).

Fictional case Érable Cycles inc. · 420-D04-AB Day 2 · © 2026 Cyber.SoHo — Educational Hub

The 72-hour rule

- Art. 33: notify the supervisory authority **without undue delay**
- Where feasible **≤ 72 hours after awareness** — calendar hours, weekends included
- Late? Give the reasons for the delay · document **every** breach (Art. 33(5))
- Art. 34: inform the people when the risk is **high**
- No **EU** (European Union) establishment → notify each authority concerned (**CNIL** (France's data protection authority), **APD-GBA** (Belgium's data protection authority)…)

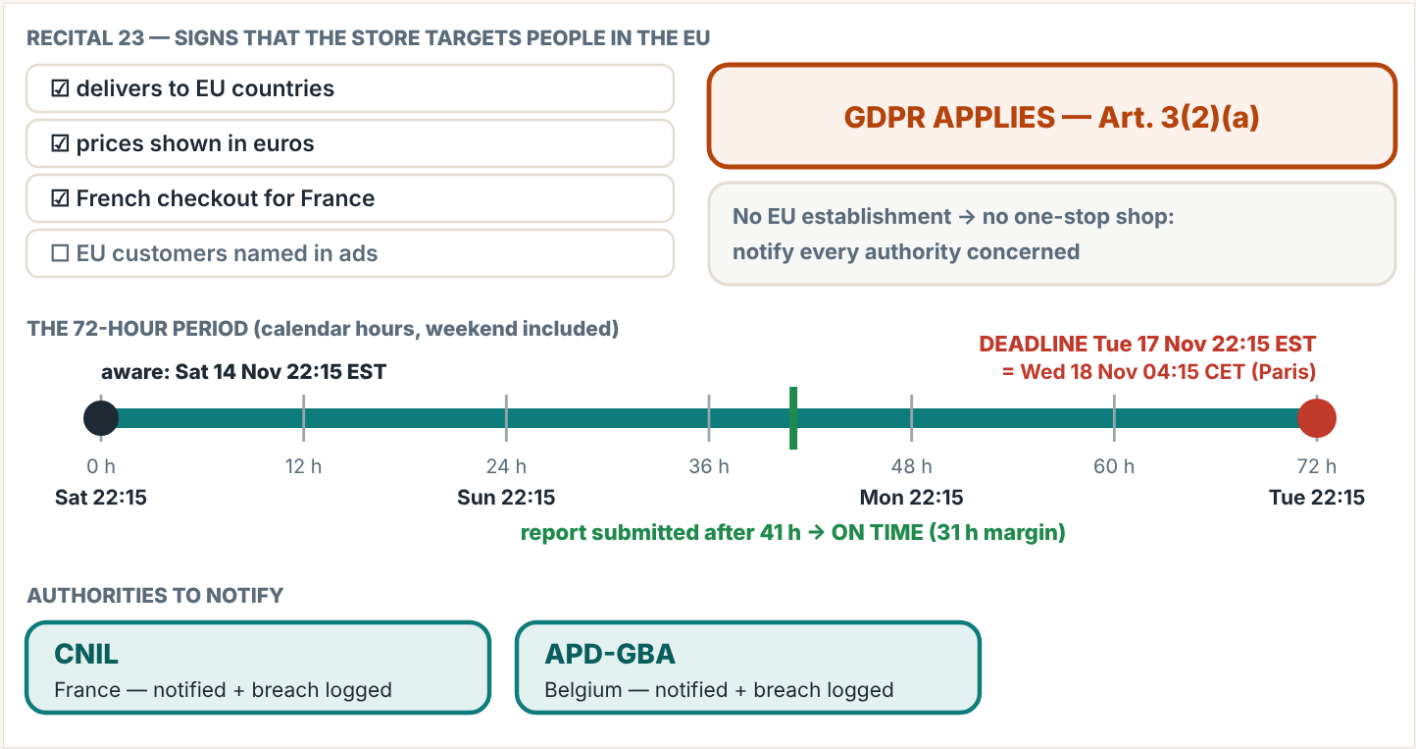
Fines and transfers

- Up to **€10 M or 2 %**: records, security, breach notification, **DPIA** (data protection impact assessment), representative
- Up to **€20 M or 4 %**: principles, lawful bases, rights, transfers
- Transfers **EU** (European Union) → Canada: **adequacy decision** for **PIPEDA** (Personal Information Protection and Electronic Documents Act) organizations (confirmed in January 2024)

KEY TERM
DPIA (data protection impact assessment) **(Art. 35)** — Impact assessment required before high-risk processing.

Example: the public database snapshot

- Sat Nov 14, 2026, 22:15 (Montréal): snapshot exposed · 410 customers in the **EU** (European Union)
- Three of four targeting signs → **GDPR** (General Data Protection Regulation) applies (Art. 3(2)(a))
- Deadline: **Tue Nov 17, 22:15 EST** (Eastern Standard Time) **= Wed Nov 18, 04:15 CET** (Central European Time)
- Notify **CNIL** (France's data protection authority) and **APD-GBA** (Belgium's data protection authority); submitted after 41 h → on time



Lesson 5 · What PCI DSS is and how it binds

- Security requirements for anyone who stores, processes or transmits card data
- Published by the **PCI SSC** (Payment Card Industry Security Standards Council) · **contractual**: card brands → acquirer → merchant
- v4.0.1 published June 11, 2024 · v4.0 retired Dec 31, 2024
- All v4 future-dated requirements mandatory since **March 31, 2025**
- Account data = cardholder data (**PAN** (primary account number), name, expiry, service code) + **SAD** (sensitive authentication data)
- **SAD** (track data, **CVV2** (card verification value), **PIN** (personal identification number)) is **never stored** after authorization

Twelve requirements in six goals

PCI DSS v4.0.1 — twelve requirements in six goals

Contractual standard (merchant agreement) · current version since June 2024 · all v4 requirements mandatory since March 31, 2025

Goal 1 Secure network and systems	Goal 2 Protect account data	Goal 3 Vulnerability management	Goal 4 Strong access control	Goal 5 Monitor and test networks	Goal 6 Information security policy
1 Network security controls	3 Protect stored account data	5 Anti-malware	7 Need to know	10 Log and monitor	12 Policies and programs
2 Secure configurations	4 Strong crypto in transmission	6 Secure systems and software	8 Identify and authenticate	11 Test security regularly	
			9 Physical access		

Scope

CDE = people, processes and technologies that store, process or transmit cardholder data or SAD
+ every system connected to it or able to affect it

Validation every year

Small merchants: SAQ + Attestation of Compliance
(SAQ A for fully outsourced e-commerce, SAQ P2PE)
Large merchants: ROC by a QSA

Fictional case Érable Cycles inc. · 420-D04-AB Day 2 · © 2026 Cyber.SoHo — Educational Hub

Scope: the cardholder data environment

- **CDE** (cardholder data environment) = people, processes, technologies that store, process or transmit card data
- Scope = **CDE** + connected or security-impacting systems
- **Segmentation** keeps other systems out of scope
- **Hosted payment page**: the card never reaches the merchant's server
- **P2PE** (point-to-point encryption): encrypted inside the terminal; only the provider decrypts
- Érable Cycles: most systems **out of scope**

KEY TERM
CDE (cardholder data environment) — The people, processes and technologies that store, process or transmit cardholder data or **SAD** (sensitive authentication data).

KEY TERM
Scope / segmentation — **CDE** (cardholder data environment) + connected or security-impacting systems / isolation that keeps other systems out of scope.

Validation: SAQ or ROC (1/2)

- Validation every year, in the form the acquirer requires
- Large merchants: **ROC** (Report on Compliance) written by a **QSA** (Qualified Security Assessor)
- Small merchants: **SAQ** (Self-Assessment Questionnaire) + signed **AOC** (Attestation of Compliance)
- Some **SAQs** (Self-Assessment Questionnaires): quarterly external scans by an **ASV** (Approved Scanning Vendor)
- Controls must work all year, not only on assessment day

KEY TERM
Acquirer — The bank that processes a merchant's card payments and enforces **PCI DSS** (Payment Card Industry Data Security Standard) through the contract.

KEY TERM
SAQ (Self-Assessment Questionnaire) **/ AOC** (Attestation of Compliance) — Self-Assessment Questionnaire / the signed Attestation of Compliance that accompanies it.

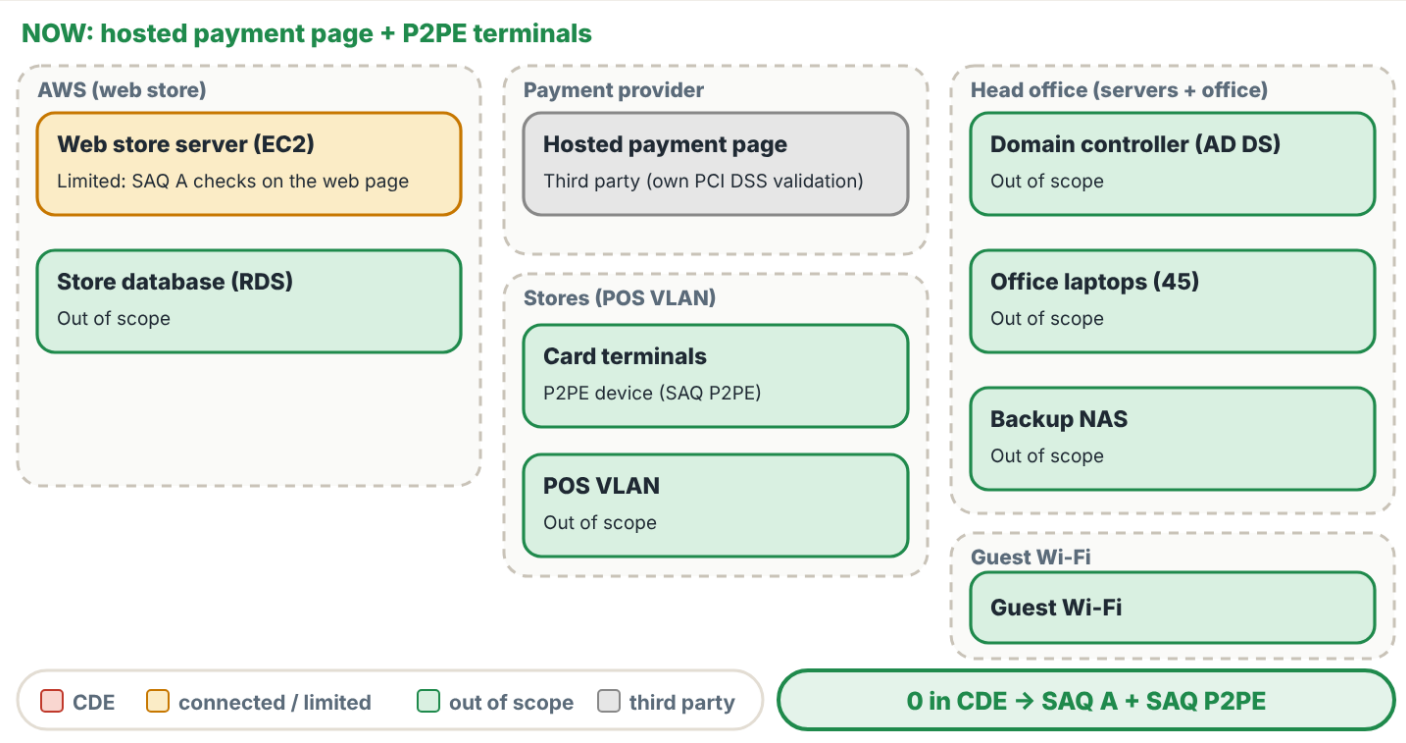
Validation: the SAQ types (2/2)

- **A** — card-not-present, fully outsourced (hosted page); script-attack criterion since 2025
- **A-EP** — site controls the redirection
- **B / B-IP** — standalone terminals
- **C-VT / C** — virtual terminal / Internet-connected payment application
- **P2PE** (point-to-point encryption) — only validated **P2PE** terminals
- **D** — everything else (card data on your own systems)

Links: PCI SSC — SAQ A update (Jan 2025) ↗

Example: which SAQ will Érable Cycles sign?

- Before: own card form + classic terminals → **5 components in the CDE** (cardholder data environment) → **SAQ** (Self-Assessment Questionnaire) **D**
- Now: hosted payment page + **P2PE** (point-to-point encryption) → **0 components in the CDE**
- → **SAQ A** (web store) + **SAQ P2PE** (stores), confirmed by the acquirer
- Open `L5_pci_scope.html` and switch designs



Lesson 6 · What CASL covers

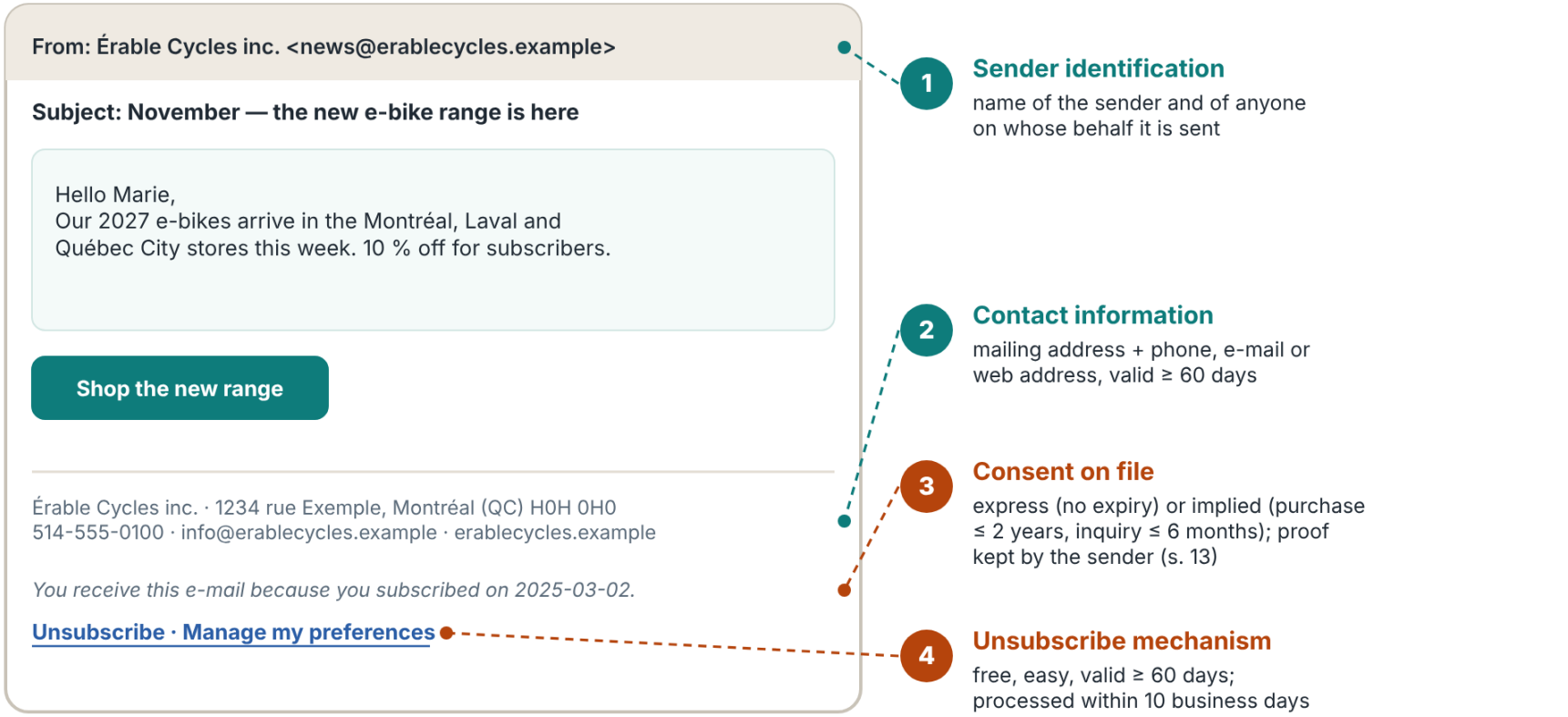
- **CASL** (Canada's Anti-Spam Legislation): S.C. 2010, c. 23 — message rules in force since **July 1, 2014**
- **CEM** (commercial electronic message): electronic message with a commercial purpose (e-mail, **SMS** (text message), social media message)
- Applies when a computer system in Canada sends or accesses it
- The Érable Cycles newsletter is a **CEM**
- Program installation rules since January 15, 2015

KEY TERM
CEM (commercial electronic message) — An electronic message with a commercial purpose sent to an electronic address.

The three requirements of every CEM

CASL — anatomy of a compliant commercial electronic message

Consent + identification + unsubscribe, for every message (s. 6)



Fictional case Érable Cycles inc. · 420-D04-AB Day 2 · © 2026 Cyber.SoHo — Educational Hub

Express vs implied consent — and proof

- **Express**: active and informed; no expiry until withdrawn
- A **pre-checked box is not acceptable** (**CRTC** (Canadian Radio-television and Telecommunications Commission) 2012-548)
- **Implied** (existing business relationship): purchase ≤ **2 years**, inquiry ≤ **6 months**
- **Proof of consent**: the sender must prove it (s. 13) — keep date, method, wording
- Tip: ask implied-consent subscribers for express consent before expiry

Enforcers, penalties and recent figures

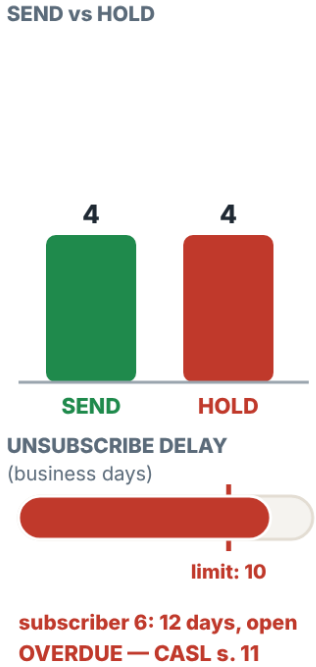
- **CRTC** (Canadian Radio-television and Telecommunications Commission): messages and computer programs · Competition Bureau: misleading messages · **OPC** (Office of the Privacy Commissioner of Canada): address harvesting
- Maximum **AMP** (administrative monetary penalty): **$1 M** (individual) · **$10 M** (business) per violation
- Apr 1 – Sep 30, 2025: 152,603 complaints to the Spam Reporting Centre
- 153 notices to produce · 123 warning letters · 1 notice of violation ($50,000)

Links: CRTC — Enforcing CASL (Apr–Sep 2025) ↗

Example: can the November newsletter go out?

- Eight consent records audited on Wed Nov 4, 2026
- 2 implied consents expired · 1 unsubscribe open for **12 business days** (overdue)
- 1 unsubscribe processed in 1 business day (on time)
- **4 SEND · 4 HOLD** — escalate the overdue request

ID	SUBSCRIBER	CONSENT	SINCE	EXPIRES	DECISION
1	a.tremblay@example.com	express	2023-05-10	never	SEND
2	b.nguyen@example.com	implied-purchase	2025-03-02	2027-03-02	SEND
3	c.roy@example.com	implied-purchase	2024-09-15	2026-09-15	HOLD
4	d.gagnon@example.com	implied-inquiry	2026-07-20	2027-01-20	SEND
5	e.martin@example.com	implied-inquiry	2026-03-01	2026-09-01	HOLD
6	f.cote@example.com	express	2024-01-12	never	HOLD
7	g.leblanc@example.com	express	2022-11-30	never	HOLD
8	h.bouchard@example.com	implied-purchase	2026-08-08	2028-08-08	SEND



Mention only: United States state laws and CRA records

- United States: no single federal privacy law for retailers; a growing number of **state laws** (**CCPA** (California Consumer Privacy Act), ...)
- Each has **applicability thresholds** → Lab 1 "other" row: "to verify"
- **CRA** (Canada Revenue Agency): keep books and records **six years** from the end of the last tax year → a **minimum**
- Privacy laws set a **maximum**: keep **PI** (personal information) only as long as necessary
- The retention schedule respects both (Day 3)

Links: IAPP state comparison table ↗ · CRA — keeping records ↗

The five texts at a glance

The five texts at a glance — inputs for the Lab 1 register

What triggers each text, who enforces it, its incident rule, its retention rule and its maximum sanction

Text	Type	Trigger (scope)	Enforcer	Incident / breach rule	Retention rule	Maximum sanction
PIPEDA	Federal law	PI in commercial activities; PI crossing borders	OPC	RROSH → OPC + people; record 24 months	Keep only as long as necessary (4.5)	$100,000 fine (offences)
Law 25	Québec law	Enterprise handling PI in Québec	CAI	Serious injury → CAI + people; register 5 years	Destroy or anonymize when purpose met	$10 M / 2 % AMP; $25 M / 4 % penal
GDPR	EU regulation	Goods offered to people in the EU (Art. 3(2))	EU authorities	Authority ≤ 72 h; people if high risk	Storage limitation (Art. 5(1)(e))	€20 M / 4 %
PCI DSS v4.0.1	Contractual standard	Merchant accepting payment cards	Acquirer / card brands	Incident response plan; inform acquirer	No SAD after authorization	Fees, fines passed on, loss of card acceptance
CASL	Federal law	Commercial electronic messages	CRTC	—	Keep proof of consent	$10 M AMP per violation

"Applies? Yes / Partly / No" with a one-sentence reason tied to a company fact is YOUR answer in Lab 1, Part A.

Fictional case Érable Cycles inc. · 420-D04-AB Day 2 · © 2026 Cyber.SoHo — Educational Hub

Lab 1 — what you will do (1/2)

- Lab 1 — Identify applicable laws and regulations (6 %)
- Part A tonight · Part B Day 3 (Tue Nov 3) · due **Fri Nov 6, 23:59** (Omnivox LÉA DropBox)
- Inputs: case file + template (laws pre-listed, one worked row)
- **Part A — Applicability Register** for **PIPEDA** (Personal Information Protection and Electronic Documents Act), Law 25, **GDPR** (General Data Protection Regulation), **PCI DSS** (Payment Card Industry Data Security Standard), **CASL** (Canada's Anti-Spam Legislation):
  - Applies? Yes / Partly / No + one-sentence reason
  - enforcer · 3 key obligations · 2 consequences · optional "other" row

Lab 1 — Part B and rubric (2/2)

- Part B: choose 2 frameworks (**CIS** (Center for Internet Security) **IG1** (Implementation Group 1) + **NIST CSF** (National Institute of Standards and Technology Cybersecurity Framework) 2.0 Profile; or **ISO/IEC** (ISO and IEC, the international standards bodies) 27001) — 3-sentence justification
- Mini **traceability matrix**: 8 requirements → 3 policies → control → evidence
- 1-page **retention schedule**: 5 record types with legal basis
- Output 3–4 pages → Project Section 3 · **CPM** (Course Procedure Manual) Chapter 1
- Rubric /6: register 2.5 · matrix 2 · retention 1 · clarity 0.5
- Course work is not an audit; fictional data only; your own work

Recall points for Day 4

- Which five texts apply to Érable Cycles, and why (tonight)
- **NIST CSF** (National Institute of Standards and Technology Cybersecurity Framework) 2.0 functions (Day 3)
- **ISO/IEC** (ISO and IEC, the international standards bodies) 27001 Annex A themes (Day 3)
- **CIS** (Center for Internet Security) Controls **IG1** (Implementation Group 1) (Day 3)
- Retention: minimum vs maximum (tonight + Day 3)
- The traceability matrix (tonight + Day 3)

Videos to watch (1/2)

Lesson 1 **Compliance – CompTIA Security+ SY0-701 – 5.4 ↗**

Professor Messer · ≈ 8 min · English

Lesson 2 **Breach video series – Risks of significant harm ↗**

Office of the Privacy Commissioner of Canada (official) · 3 min 28 s · English (French version on the OPC site)

Lesson 2 **Breach video series – Keeping records ↗**

Office of the Privacy Commissioner of Canada (official) · 2 min 11 s · English

Lesson 3 **Quebec's Law 25 Explained: Quick Data Privacy Guide for Businesses ↗**

Clym · ≈ 3 min · English

Lesson 3 **Capsule 9 — Que faire en cas d'incident touchant des renseignements personnels ? ↗**

Commission d'accès à l'information du Québec (official) · ≈ 5 min (13 capsules ≈ 60 min in total) · French

Lesson 3
Capsule 11 — Comment réfléchir à la protection des renseignements personnels dès le début d'un projet ? ↗

Commission d'accès à l'information du Québec (official) · ≈ 5 min · French

Videos to watch (2/2)

Lesson 4 **GDPR Explained: Quick Data Privacy Guide for Businesses ↗**

Clym · ≈ 3 min · English

Lesson 4 **Privacy – CompTIA Security+ SY0-701 – 5.4 ↗**

Professor Messer · ≈ 6 min · English

Lesson 5 **PCI DSS Implementation Guide: 3. Scoping and Cardholder Data Environment ↗**

qvisoft · ≈ 3 min · English

Lesson 5 **PCI DSS 4.0 Explained: 12 Requirements, How to Stay Compliant ↗**

pTrackly (channel: Trang Mora) · ≈ 6 min (the last 30 s present the publisher's product) · English

Lesson 6 **Spam — A compliance feast ↗**

CRTC (official) · ≈ 1 min · English (French on the CRTC site)

Lesson 6 **Spam and Telemarketing — Stir in the regulations ↗**

CRTC (official) · ≈ 1.5 min · English (French on the CRTC site)

Key official links (1/2)

- **Office of the Privacy Commissioner of Canada (OPC) ↗**
  Federal privacy regulator: **PIPEDA** (Personal Information Protection and Electronic Documents Act) guidance, complaints, investigations and breach reports.
- **OPC — What you need to know about mandatory reporting of breaches of security safeguards ↗**
  Definition of a breach, the **RROSH** (real risk of significant harm) test, reporting, notification and the 24-month record.
- **PIPEDA — consolidated text (Justice Laws Website) ↗**
  Official text of the Personal Information Protection and Electronic Documents Act.
- **Bill C-36 on LEGISinfo (Parliament of Canada) ↗**
  Progress of the Protecting Privacy and Consumer Data Act bill through Parliament.
- **Commission d'accès à l'information du Québec (CAI) ↗**
  Québec's regulator for the Private Sector Act as amended by Law 25.
- **Act respecting the protection of personal information in the private sector (CQLR c. P-39.1) — LégisQuébec ↗**
  Official text of Québec's Private Sector Act as amended by Law 25.
- **CRTC — CASL: spam and malware ↗**
  CRTC (Canadian Radio-television and Telecommunications Commission) entry page for **CASL** (Canada's Anti-Spam Legislation) rules, compliance resources and enforcement.
- **CRTC — Frequently asked questions about CASL ↗**
  Consent, identification, unsubscribe rules and maximum penalties.

Key official links (2/2)

- **GDPR — European Union Regulation (EU) 2016/679 on EUR-Lex ↗**
  Official text of the General Data Protection Regulation.
- **European Data Protection Board (EDPB) ↗**
  EU (European Union) body that publishes the official **GDPR** (General Data Protection Regulation) guidelines (for example on breach notification).
- **CNIL — missions of the authority (English pages) ↗**
  Example of an **EU** supervisory authority that receives breach notifications.
- **PCI Security Standards Council (PCI SSC) ↗**
  Publisher of **PCI DSS** (Payment Card Industry Data Security Standard), the **SAQs** (Self-Assessment Questionnaires) and the **P2PE** (point-to-point encryption) standard.
- **NIST Cybersecurity Framework (CSF 2.0) ↗**
  Voluntary framework with six functions: Govern, Identify, Protect, Detect, Respond, Recover.
- **CIS Critical Security Controls v8.1 ↗**
  18 controls with Implementation Groups; **IG1** (Implementation Group 1) is the starting point for small organizations.
- **Cyber.SoHo — Legal Notice, Terms of Use and Acceptable Use Policy (v2.0) ↗**
  The rules that apply to every Cyber.SoHo material, including this lecture and its code.
- **VirusTotal — URL scanner ↗**
  Paste any link to have it checked by many security engines before you open it.

END OF THE LECTURE

Questions — then the break and Lab 1



- Five texts: **PIPEDA** (Personal Information Protection and Electronic Documents Act) · Law 25 · **GDPR** (General Data Protection Regulation) · **PCI DSS** (Payment Card Industry Data Security Standard) v4.0.1 · **CASL** (Canada's Anti-Spam Legislation)
- 19:30 break · 19:45 Lab 1, Part A
- Bring the case file and the Lab 1 template